

OpenBreach Security Assessment Report

TECHNICAL DOSSIER

Technical Remediation Report for Tonalá

Formal technical remediation report generated from normalized structured evidence.

Target: Tonalá | Public ID: mx-jalisco-tonala | Audience: Technical

Executive summary

Tonalá is currently assessed at critical risk with score 83/100 based on 6 normalized reportable finding(s). This technical report preserves uncertainty, distinguishes evidence from inference, and orders remediation work by severity, evidence clarity, and verification readiness.

Report context

TARGET	Tonalá
PUBLIC ID	mx-jalisco-tonala
AUDIENCE	Technical
GENERATED AT	2026-05-18T02:46:12.606Z
GENERATED BY	deterministic-fallback

Priority actions

PRIORITY 1	Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release. Verification: Re-run the same bounded check after the mitigation is applied.
PRIORITY 2	Enable HSTS after confirming HTTPS is stable for the site and subdomains. Verification: Re-run the same bounded check after the mitigation is applied.
PRIORITY 3	Add a tested Content-Security-Policy that limits script, frame, and object sources. Verification: Re-run the same bounded check after the mitigation is applied.
PRIORITY 4	Send X-Content-Type-Options: nosniff on HTML and static asset responses. Verification: Re-run the same bounded check after the mitigation is applied.
PRIORITY 5	Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible. Verification: Re-run the same bounded check after the mitigation is applied.

Scope

Tonalá was treated as the scoped public-facing target for this report. The report generator normalized the available structured input and limited the output to the provided target context.

PRIMARY PUBLIC URL	https://tonala.gob.mx
REGION OR STATE REFERENCE	Jalisco

Authorization

No explicit authorization object was supplied. The report generator treated the input as evidence-only and did not add new tests or claims.

- No detailed authorization fields were supplied in the current input payload.

Methodology

The report was assembled from structured inputs, normalized into a consistent evidence model, and then rendered into audience-specific remediation guidance.

- Reviewed structured scan evidence for <https://tonala.gob.mx>.
- Normalized flexible structured input into a consistent report contract before generating the PDFs.
- Preserved only evidence-backed observations and did not add new findings without source support.
- Excluded exploit payloads, credential use, and operational attack instructions from the output.

Findings overview

The ordered finding set below reflects the normalized evidence currently available for Tonalá. Items with stronger evidence and higher severity appear first.

HIGH	1
MEDIUM	4
LOW	1
TOP FINDING	WordPress 6.4 requires patch review
TOP FINDING	Missing HTTP Strict Transport Security
TOP FINDING	Missing Content Security Policy

Detailed findings

1. WordPress 6.4 requires patch review

SEVERITY	high
STATUS	observed
CONFIDENCE	high
CATEGORY	known-vulnerability

DESCRIPTION

The scanner observed a WordPress 6.4 generator string. This MVP treats the version as a known-risk demo match when confidence is high, without claiming exploitation.

EVIDENCE

wordpress 6.4; confidence 0.8; references CVE-2024-31210.

RECOMMENDED REMEDIATION

Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release.

REMEDIATION STEPS

- Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release.
- Assign an owner and due date before treating the item as resolved.

VERIFICATION STEPS

- Re-run the same bounded check after the mitigation is applied.

- Record the post-change result for wordpress 6.4 requires patch review and compare it with the current evidence.

2. Missing HTTP Strict Transport Security

SEVERITY	medium
STATUS	observed
CONFIDENCE	medium
CATEGORY	headers

DESCRIPTION

A baseline browser security response header was not observed in the passive HTTP response.

EVIDENCE

strict-transport-security was not present in the selected response headers.

RECOMMENDED REMEDIATION

Enable HSTS after confirming HTTPS is stable for the site and subdomains.

REMEDIATION STEPS

- Enable HSTS after confirming HTTPS is stable for the site and subdomains.
- Assign an owner and due date before treating the item as resolved.

VERIFICATION STEPS

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing http strict transport security and compare it with the current evidence.

3. Missing Content Security Policy

SEVERITY	medium
STATUS	observed
CONFIDENCE	medium
CATEGORY	headers

DESCRIPTION

A baseline browser security response header was not observed in the passive HTTP response.

EVIDENCE

content-security-policy was not present in the selected response headers.

RECOMMENDED REMEDIATION

Add a tested Content-Security-Policy that limits script, frame, and object sources.

REMEDIATION STEPS

- Add a tested Content-Security-Policy that limits script, frame, and object sources.
- Assign an owner and due date before treating the item as resolved.

VERIFICATION STEPS

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing content security policy and compare it with the current evidence.

4. Missing X-Content-Type-Options

SEVERITY	medium
STATUS	observed
CONFIDENCE	medium
CATEGORY	headers

DESCRIPTION

A baseline browser security response header was not observed in the passive HTTP response.

EVIDENCE

x-content-type-options was not present in the selected response headers.

RECOMMENDED REMEDIATION

Send X-Content-Type-Options: nosniff on HTML and static asset responses.

REMEDIATION STEPS

- Send X-Content-Type-Options: nosniff on HTML and static asset responses.
- Assign an owner and due date before treating the item as resolved.

VERIFICATION STEPS

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for missing x-content-type-options and compare it with the current evidence.

5. Public admin path is reachable

SEVERITY	medium
STATUS	observed
CONFIDENCE	medium
CATEGORY	admin-exposure

DESCRIPTION

One or more common CMS or generic admin paths responded successfully to safe passive checks.

EVIDENCE

/wp-login.php returned 200.

RECOMMENDED REMEDIATION

Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible.

REMEDIATION STEPS

- Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible.
- Assign an owner and due date before treating the item as resolved.

VERIFICATION STEPS

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for public admin path is reachable and compare it with the current evidence.

6. CMS fingerprint was detected

SEVERITY	low
STATUS	observed
CONFIDENCE	low
CATEGORY	cms

DESCRIPTION

Public page evidence revealed a likely CMS fingerprint. This is informational unless combined with other risk evidence.

EVIDENCE

wordpress 6.4; confidence 0.8; evidence generator:WordPress 6.4, marker:wordpress.

RECOMMENDED REMEDIATION

Keep CMS core, extensions, and themes patched, and remove unnecessary public version disclosures where practical.

REMEDIATION STEPS

- Keep CMS core, extensions, and themes patched, and remove unnecessary public version disclosures where practical.
- Assign an owner and due date before treating the item as resolved.

VERIFICATION STEPS

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for cms fingerprint was detected and compare it with the current evidence.

Skipped and denied tests

These activities were skipped, denied, or intentionally excluded from the current report scope.

- Active exploitation, credential testing, fuzzing, destructive requests, and private-network actions were out of scope.

Validation status

The following notes summarize the provided validation state and observed status information.

- The passive target appeared reachable during the supplied observation window.
- Observed HTTP status: 200.
- No explicit controlled validation result was supplied in the structured input.

Limitations

The report remains bounded by the supplied evidence, missing fields, and explicit safety constraints.

- Authorization scope details were not fully supplied.
- No explicit validation result set was supplied, so unresolved uncertainty remains.
- The report summarizes the provided evidence and should not be interpreted as proof of exploitability or breach.

Remediation checklist

Use this checklist to coordinate the next engineering actions and their owners.

- Confirm the WordPress core and plugin patch level, then upgrade to the latest supported release.
- Assign an owner and due date before treating the item as resolved.
- Confirm ownership for wordpress 6.4 requires patch review before the next review cycle.
- Enable HSTS after confirming HTTPS is stable for the site and subdomains.
- Confirm ownership for missing http strict transport security before the next review cycle.
- Add a tested Content-Security-Policy that limits script, frame, and object sources.
- Confirm ownership for missing content security policy before the next review cycle.
- Send X-Content-Type-Options: nosniff on HTML and static asset responses.
- Confirm ownership for missing x-content-type-options before the next review cycle.
- Restrict administrative entry points with access controls, MFA, and monitoring where operationally possible.

Verification guidance

After mitigation, repeat only the same bounded checks and compare the new evidence against this report.

- Re-run the same bounded check after the mitigation is applied.
- Record the post-change result for wordpress 6.4 requires patch review and compare it with the current evidence.
- Record the post-change result for missing http strict transport security and compare it with the current evidence.
- Record the post-change result for missing content security policy and compare it with the current evidence.
- Record the post-change result for missing x-content-type-options and compare it with the current evidence.
- Record the post-change result for public admin path is reachable and compare it with the current evidence.
- Record the post-change result for cms fingerprint was detected and compare it with the current evidence.